

The slide features a light gray background with several decorative elements: a large white circle in the top-left corner, a solid purple circle in the top-left area, a purple-to-white gradient bar in the top-right corner, a small purple-to-white gradient circle in the bottom-right area, a large purple-to-white gradient circle in the bottom-right corner, and a purple-to-white gradient bar in the bottom-left corner.

PROG IV: **ORM e JWT**

Profª. Tainá Isabela

Introdução ao Desenvolvimento Backend Moderno com NestJS, ORM e JWT

No cenário contemporâneo do desenvolvimento de sistemas de informação, a construção de aplicações backend exige estruturas que garantam escalabilidade, manutenibilidade e segurança robusta.

O nosso objetivo consiste em analisar a integração sinérgica dessas tecnologias sob uma perspectiva de engenharia de software de nível universitário. Através desta exposição teórica e prática, serão discutidos os padrões arquiteturais subjacentes que viabilizam o design de APIs RESTful profissionais, seguras e de alta performance.

Arquitetura do NestJS: Inversão de Controle e Injeção de Dependências

O NestJS destaca-se no ecossistema Node.js por impor uma arquitetura fortemente inspirada em padrões de design corporativos. As dependências entre classes, tais como serviços e repositórios, são declaradas e injetadas de forma automática através de decoradores especiais como **@Injectable()**.

Essa abordagem promove um desacoplamento entre as camadas do sistema, o que facilita o isolamento de componentes para a realização de testes unitários automatizados. A organização estrutural baseada em módulos (**@Module**) encapsula o escopo e dita a visibilidade e o compartilhamento de provedores por toda a aplicação.

Conceitos Fundamentais de ORM: A Abstração da Camada de Dados

O **Mapeamento Objeto-Relacional (ORM)** resolve a clássica incompatibilidade de impedância entre o paradigma de programação orientada a objetos e o modelo de dados relacional de bancos de dados SQL. Em vez de redigir instruções SQL puras de maneira dispersa na aplicação, o desenvolvedor define a estrutura das tabelas por meio de classes de entidades de software.

O ORM encapsula as operações de baixo nível de criação, leitura, atualização e exclusão (CRUD) por meio de uma API orientada a objetos. No contexto do ecossistema NestJS, ferramentas consagradas como **TypeORM** e **Prisma** são integradas nativamente, encapsulando conexões, gerenciando pools de acesso, lidando com transações ACID complexas e provendo tipagem estática ponta a ponta que previne falhas em tempo de compilação.

Bases Teóricas do Paradigma ORM: Data Mapper vs. Active Record

A literatura de arquitetura de software de padrões corporativos descreve dois modelos principais para a persistência em ORMs: **Active Record** e **Data Mapper**. O padrão Active Record unifica a **representação dos dados e o comportamento de persistência dentro da própria entidade**, facilitando operações rápidas, mas violando o Princípio de Responsabilidade Única.

Por outro lado, o padrão **Data Mapper** isola completamente a representação dos dados na entidade das operações de persistência, que ficam delegadas a uma classe externa denominada **Repositório (Repository)**. O TypeORM implementa prioritariamente o padrão Data Mapper no NestJS, garantindo que as regras de negócio residam em modelos anêmicos ou puramente focados no domínio, enquanto a persistência permanece desacoplada.

O Papel das Migrations

A evolução controlada de uma base de dados relacional em ambientes de produção exige um mecanismo formal conhecido como migrações (migrations). As migrações funcionam como um sistema de controle de versão para o esquema do banco de dados, registrando cada alteração estrutural, como inclusões de colunas ou chaves estrangeiras, em arquivos de script ordenados cronologicamente.

Ao invés de permitir alterações manuais ou a sincronização automatizada destrutiva (**synchronize: true**), o NestJS e o ORM utilizam scripts de migração que contêm métodos para aplicar as mudanças (up) e reverter as alterações caso ocorra um imprevisto (down). Este procedimento mitiga riscos de perda de dados e garante a consistência do ambiente de desenvolvimento ao de produção.

Autenticação Descentralizada e o Protocolo HTTP Stateless

O protocolo HTTP, que serve de fundação para APIs RESTful, possui natureza stateless, significando que cada requisição entre cliente e servidor é **tratada de forma isolada**, sem retenção de contexto nativo. Tradicionalmente, o estado da sessão era mantido na memória do servidor através de cookies de sessão.

Contudo, essa abordagem tradicional apresenta sérias limitações de escalabilidade horizontal em arquiteturas de microsserviços ou sistemas distribuídos com balanceamento de carga.

A autenticação baseada em **tokens** descentraliza essa responsabilidade, transferindo o estado da sessão para o cliente. Uma vez validada a identidade do usuário, o servidor emite um artefato assinado digitalmente, que deve ser anexado em todas as subsequentes interações de rede.

Anatomia Estrutural do JSON Web Token (JWT)

O **JSON Web Token (JWT)** é um padrão aberto definido pela RFC 7519 que especifica uma estrutura compacta e autocontida para a transmissão segura de informações entre partes como um objeto JSON. Um token JWT é composto estritamente por três seções distintas separadas por pontos: **o Cabeçalho (Header), a Carga Útil (Payload) e a Assinatura (Signature)**, codificadas em formato Base64Url. O Header especifica o algoritmo de criptografia empregado, como o HMAC SHA256 ou o RSA. O Payload armazena as alegações (claims), que consistem em declarações sobre o usuário e metadados adicionais, como o identificador do sujeito (sub) e o carimbo de expiração (exp). A Signature garante que o token não tenha sido modificado de forma maliciosa durante o tráfego de rede.

Criptografia Simétrica vs. Assíncrona no Escopo do JWT

A integridade de um JSON Web Token apoia-se em mecanismos de assinatura digital que podem ser estruturados sob duas abordagens criptográficas distintas. A criptografia **simétrica** emprega uma **única chave secreta compartilhada entre o emissor do token e o validador**, utilizando algoritmos como o HS256; embora ágil, exige ampla confiança na distribuição da chave secreta.

Em contrapartida, a criptografia assimétrica **utiliza um par de chaves composto por uma chave privada**, guardada estritamente sob posse do servidor de autenticação para assinar os tokens, e uma chave pública, distribuída abertamente para que qualquer serviço possa verificar a autenticidade do token com algoritmos como o RS256. Esta última é a metodologia recomendada para ecossistemas complexos de microsserviços.

Modelagem do Módulo de Conectividade com o Banco de Dados

A implementação prática inicia-se com a configuração do módulo global de persistência de dados no NestJS. Através do pacote `@nestjs/typeorm`, importa-se o método estático `TypeOrmModule.forRoot()` no módulo raiz da aplicação (`AppModule`).

Este método inicializa o pool de conexões com o banco de dados especificado, recebendo parâmetros cruciais como o tipo do driver, o endereço do servidor, as credenciais de acesso, e os caminhos de mapeamento das entidades polimórficas.

Utiliza-se de forma imperativa o padrão de variáveis de ambiente gerenciadas pelo `ConfigModule` do NestJS para evitar a exposição indevida de dados sensíveis diretamente no código-fonte, em estrita conformidade com os princípios modernos de segurança de software corporativo.

Modelagem de Entidades e Relacionamentos no ORM

No paradigma do TypeORM, as entidades são modeladas como classes TypeScript decoradas com o marcador **@Entity()**. As colunas e os mapeamentos de tipos de dados são definidos por meio de decoradores como **@Column()** e **@PrimaryGeneratedColumn()**.

O estabelecimento de integridade referencial e os relacionamentos de chaves estrangeiras entre as tabelas do banco de dados, tais como um-para-muitos ou muitos-para-muitos, são expressos de forma declarativa utilizando decoradores como **@ManyToOne()** e **@OneToMany()**.

O mapeamento correto dessas anotações permite ao mecanismo ORM realizar operações complexas de junção (joins) de tabelas e carregamento relacional de forma automatizada e performática através de instruções otimizadas de consulta.

O Padrão Data Access Object com Repositórios Customizados

Para interagir com as entidades no banco de dados, o NestJS injeta instâncias de repositórios diretamente nos serviços de negócio utilizando o decorador **@InjectRepository()**. O repositório encapsula o padrão **Data Access Object (DAO)**, provendo métodos assíncronos integrados como **find()**, **findOne()**, **save()** e **remove()**.

Caso as consultas exijam regras lógicas complexas ou otimizações específicas, utiliza-se a API do QueryBuilder exposta pelo ORM. O QueryBuilder permite construir consultas SQL programáticas com tipagem estática forte, mitigando riscos de vulnerabilidades de segurança severas como o SQL Injection, visto que o ORM parametriza automaticamente todos os valores de entrada recebidos da requisição.

Estruturação do Processo de Hashing de Senhas

O armazenamento seguro de credenciais de usuários em banco de dados obstaculiza a retenção de senhas em texto puro, prática considerada falha gravíssima de segurança. O serviço de usuários (UserService) deve aplicar uma função criptográfica de hashing unidirecional antes da persistência no banco de dados.

Bibliotecas padronizadas como o **bcrypt** ou **argon2** incorporam mecanismos de decodificação complexos e a adição de um valor aleatório conhecido como **salt**.

O salt impede ataques computacionais baseados em tabelas pré-computadas de hashes, conhecidas como Rainbow Tables. Durante a persistência, o método `save()` do repositório recebe a string do hash criptográfico gerado, assegurando o cumprimento das diretrizes de segurança regulatórias internacionais.

Arquitetura do Módulo de Autenticação (AuthModule)

O módulo de autenticação (AuthModule) coordena o fluxo de login do sistema e as validações de acesso, congregando o UsersModule e o pacote @nestjs/jwt. A configuração do token ocorre via JwtModule.register(), onde estipula-se a chave secreta de assinatura ou os caminhos de arquivos das chaves assimétricas, além do **tempo de expiração** (expiresIn).

O serviço de autenticação (**AuthService**) implementa o método assíncrono **validateUser()**, que recupera o registro cadastral, compara o hash da senha informada com o armazenado e, se válidos, invoca o método de geração do token propriamente dito, encapsulando os dados públicos do usuário dentro do payload do JWT.

Interceptação e Segurança de Rotas com NestJS Guards

A proteção de pontos de acesso expostos pela API contra requisições não autorizadas é efetuada no NestJS de maneira declarativa utilizando componentes conhecidos como Guardas (**Guards**). Um guarda é uma classe decorada com **@Injectable()** que implementa a interface `CanActivate`.

O método `canActivate()` intercepta a requisição HTTP em trânsito antes de sua chegada ao método do controlador (`Controller`).

O guarda inspeciona o cabeçalho de autorização da requisição em busca do padrão **Bearer <token>**, extrai a string identificadora do JWT e delega a validação criptográfica ao módulo `Passport` ou à biblioteca JWT interna do framework, retornando um valor booleano indicativo de permissão de acesso.

Implementação Prática com Passport e JWT Strategy

O NestJS abstrai a complexidade do ecossistema Passport de autenticação por meio do uso de estratégias customizadas via pacote `@nestjs/passport`. Cria-se uma classe base denominada `JwtStrategy` que estende a classe abstrata `PassportStrategy`.

No construtor da estratégia, definem-se opções imperativas como `jwtFromRequest: ExtractJwt.fromAuthHeaderAsBearerToken()` e a validação da assinatura criptográfica. O método `validate()` processa de forma automática o payload decodificado do JWT após a confirmação de integridade física do token, injetando os dados do usuário extraídos diretamente no objeto de requisição do Express ou Fastify (`req.user`), disponibilizando-o para o escopo do controlador.

O Mecanismo de Renovação de Acesso: Refresh Tokens

Para elevar a segurança, os tokens de acesso (**Access Tokens**) gerados devem possuir um tempo de expiração curto, limitando a janela de oportunidade caso ocorra o vazamento do artefato. Contudo, exigir logins frequentes degrada a experiência do usuário, problema mitigado através do padrão de Refresh Tokens.

O Refresh Token possui validade estendida e é armazenado de forma segura em banco de dados ou cookies HttpOnly. Quando o Access Token expira, o cliente envia o Refresh Token a uma rota dedicada da API.

O servidor valida a persistência e integridade desse token estendido e emite um novo par de chaves de acesso, minimizando o impacto de vazamentos e revogando acessos remotos com eficiência.

Controle de Acesso Baseado em Papéis: RBAC e Claims

Além de autenticar a identidade do usuário, o sistema deve aplicar autorizações granulares para delimitar as ações permitidas dentro do sistema. **O modelo RBAC (Role-Based Access Control)** mapeia papéis específicos, como administrador ou usuário comum, às contas do sistema.

No NestJS, essa arquitetura é modelada criando decoradores customizados de metadados, como **@Roles()**, e vinculando-os aos métodos dos controladores. Um guarda de autorização customizado intercepta os metadados injetados na rota através do utilitário Reflector, confronta esses dados com os privilégios contidos nas alegações (claims) do JWT do usuário e nega a execução com um erro HTTP 403 Forbidden caso haja incompatibilidade.

Otimização de Consultas de Banco e Segurança em Larga Escala

Em cenários de alta concorrência corporativa, a integração entre o NestJS, ORM e JWT enfrenta desafios de escalabilidade e latência física de rede. Um estudo de caso clássico envolve a degradação de performance decorrente de consultas excessivas ao banco de dados pelo ORM durante validações de rotas protegidas.

Se o guarda de autenticação consultar o banco de dados a cada requisição HTTP para verificar o status cadastral do usuário, cria-se um gargalo de I/O massivo. A mitigação arquitetural desse cenário envolve codificar informações críticas imutáveis no payload do próprio JWT ou introduzir uma camada intermediária de armazenamento em cache na memória volátil utilizando bancos de dados NoSQL chave-valor rápidos, como o Redis.

Vantagens e Limitações da Abordagem Arquitetural Escolhida

A união estrutural entre NestJS, ORM e JWT confere expressivas vantagens competitivas de engenharia. O NestJS provê uma base modular sólida para manutenção de grandes equipes; o ORM acelera a produtividade ao abstrair o dialeto SQL e mitigar ataques e erros de tipagem; o JWT garante escalabilidade ao desonerar o servidor de gerenciar estados em memória RAM corporativa. Em contrapartida, as limitações envolvem uma curva de aprendizado íngreme para iniciantes devido à complexidade conceitual, o risco de perda de performance em consultas complexas mal otimizadas pelo ORM e a impossibilidade nativa de invalidação imediata de um JWT antes de sua expiração natural.

Erros Comuns e Equívocos Frequentes no Desenvolvimento

Entre os equívocos mais recorrentes cometidos por desenvolvedores juniores destaca-se o vazamento de dados sensíveis, como chaves privadas ou senhas, pela inclusão inadvertida desses dados no payload público do JWT ou pelo esquecimento da exclusão do campo de senha nas consultas de entidades do ORM.

Outro erro técnico clássico relaciona-se ao problema de consulta conhecida como **N+1**, onde o ORM executa múltiplas consultas consecutivas e individuais para carregar relacionamentos de entidades em um laço de repetição, ao invés de compilar uma única instrução otimizada com junção de tabelas (Eager Loading ou explicitamente via Join Queries).

Tendências Atuais no Desenvolvimento de APIs Seguras

O desenvolvimento backend moderno direciona-se progressivamente rumo ao uso de abordagens agnósticas de banco de dados e à descentralização de segurança ainda mais profunda. Tecnologias de mapeamento baseadas em motores de geração estática de tipos em tempo de compilação pura, como o Prisma, ganham tração frente aos ORMs clássicos baseados em decoradores experimentais.

Na esfera de segurança, observa-se uma migração em direção ao padrão OAuth 2.1 e à substituição gradual do JWT tradicional por formatos inovadores como PASETO (Platform-Agnostic Security Tokens), que eliminam falhas de design conhecidas do padrão JWT, proibindo o uso de algoritmos fracos ou inseguros por padrão.

Conclusão

Em suma, a consolidação de uma API robusta e escalável em ambiente NestJS exige profunda compreensão técnica de seus componentes modulares de persistência e autenticação. A abstração fornecida pelos ORMs não desobriga o engenheiro de software de compreender o comportamento interno do banco de dados relacional e a modelagem ágil de seus índices.

Da mesma forma, o uso de JSON Web Tokens impõe responsabilidade rigorosa sobre a gestão do ciclo de vida das chaves criptográficas. O sucesso no design de sistemas corporativos distribui-se no equilíbrio criterioso entre a facilidade de desenvolvimento, o desempenho do hardware operacional e a segurança da informação trafegada na rede.

Questionário



Exercício:

Faça integração com o typeorm e inclua a autenticação com o JWT em seu projeto.